

タイトル: Log4Shell(JVNDB-2021-005429・CVE-2021-44228 など)脆弱性に関する 調査レポート II 続き

被害の概要

2021 年 12 月、Apache Log4j ライブラリに深刻な脆弱性（CVE-2021-44228）が発見されて以来、世界中の多数の企業、組織、政府機関、そして個人利用者がサイバー攻撃の標的となりました。報告された被害には、個人情報の漏洩、業務の停止、マルウェア感染、大規模なボットネットの構築などが含まれます。特にこの脆弱性の深刻さは、Log4j がクラウドサービス、Web アプリケーション、IoT デバイス、エンタープライズソフトウェアなど、非常に幅広い分野で利用されていたことに起因しています。そのため、Amazon、Apple、Microsoft、Twitter といった世界的な大企業も影響を受けた事例が確認されました。

この脆弱性は、攻撃者が任意のコードをリモートで実行できる「リモートコード実行（RCE）」を可能にしたため、システム内部に不正アクセスされるリスクが非常に高まりました。攻撃者はこれを利用して、バックドアの設置、暗号通貨のマイニング、ランサムウェアの配布など、様々な悪意のある行為を実行可能でした。

Log4Shell が公表された 2021 年 12 月初頭には、公開からわずか数時間のうちにハッカーたちが自動スキャンツールを使ってインターネット上のサーバーを探索・攻撃し、全世界で数百万件規模の攻撃が行われたと報告されています。この影響により、米国国家安全保障局（NSA）やサイバーセキュリティ・インフラセキュリティ庁（CISA）などが緊急対応を呼びかけ、Log4Shell は「過去 10 年間で最も危険な脆弱性の一つ」と評価されました。さらに、Log4j の追加脆弱性（CVE-2021-45046、CVE-2021-45105、CVE-2021-44832）も続々と発見され、DoS 攻撃や設定ファイルの改ざんなど、新たな攻撃経路が確認されました。これらへの根本的な対応には、継続的なパッチの適用と監視体制の強化が不可欠とされています。

Amazon（AWS）の対応

Amazon Web Services（AWS）は、Java 仮想マシン（JVM）において JNDI 機能を無効化する hot patch（ホットパッチ）」を提供し、CVE-2021-44228 および CVE-2021-45046 に対応しました。このパッチはオープンソースとしても公開され、ユーザーが迅速に対応できるよう配慮されました。

Microsoft の対応

Microsoft は、CVE-2021-44228 に関するガイダンスを公開し、影響を受ける製品のリストや緩和策、Microsoft Defender などのセキュリティツールの活用方法を提示しました。攻撃検出や調査方法についても詳細に説明され、企業による早期対応に貢献しました。

Apple の対応

Apple は、Xcode 13.3 のセキュリティアップデートにおいて、Apache Log4j2 および Jackson ライブラリに存在する脆弱性に対処しました。特に、開発者向けツールである iTMSTransporter の安全性が強化されました。

Twitter の状況

Twitter からは CVE-2021-44228 に関する公式な発表は確認されていません。しかし、Cloud Security Alliance によると、#log4j や #log4shell などのハッシュタグを通じて、世界中のセキュリティ専門家が情報を共有し、初動対応の迅速化に貢献したと報告されています。

このように、Log4j の脆弱性は非常に広範囲に影響を及ぼし、重大なセキュリティリスクを生み出しました。今後も同様の問題に備えるためには、定期的な脆弱性診断、迅速なパッチ適用、セキュリティ体制の強化が重要となります。

参考文献：

- [1] [h"ps://www.crowdstrike.com/blog/log4j-vulnerability-analysis/](https://www.crowdstrike.com/blog/log4j-vulnerability-analysis/)
- [2] National Vulnerability Database (NVD):(<https://nvd.nist.gov/vuln/detail/cve-2021-44228>)
- [3] (<https://cve.mitre.org/cgibin/cvename.cgi?name=CVE-2021-45046>)